THE ETHICAL HACKER

Ethical Hacker (a.k.a Penetration Tester / Red Teamer)

What they do

- They're the "legal hackers" hired by companies to break into systems **before the bad guys do**.
- Simulate real-world cyberattacks on apps, networks, and infrastructure.
- Write detailed reports: what they hacked, how they hacked it, and how to fix it.

Basically: *They attack with permission so the company doesn't get attacked without it.*

Key Skills / Technologies

- **Networking & OS Knowledge:** TCP/IP, DNS, HTTP, Linux, Windows internals.
- **Penetration Testing Tools:** Metasploit, Nmap, Burp Suite, Wireshark, Nessus, John the Ripper, Hydra.
- **Web Security:** SQL Injection, XSS, CSRF, authentication flaws.
- **Cloud Hacking:** AWS, Azure, GCP security flaws (if modern pen testing).
- **Social Engineering (sometimes):** phishing & physical security awareness.

Certifications (Recommended Path)

- **Beginner → Intermediate:**
    - CompTIA Security+ (foundation).
    - CEH (Certified Ethical Hacker) — most popular entry cert.
- **Pro Level:**
    - OSCP (Offensive Security Certified Professional) — real hardcore, hands-on hacking.
    - GPEN (GIAC Penetration Tester).
    - eJPT / PNPT (cheaper but respected certs for beginners).

Programming / Scripting Languages You Need

- **Python** → automate attacks, build exploits, scripts for scanning.
- **Bash** (Linux) & **PowerShell** (Windows) → scripting system-level attacks.
- **JavaScript** → for web attacks (XSS, DOM manipulation).

- **SQL** → for SQL Injection attacks.
- **C / C++** → if you want to go *deep* into exploit development or reverse engineering.

Career Path

1. Start as **SOC Analyst / Security Analyst** (blue team experience helps).
2. Move into **Ethical Hacking / Pen Testing**.
3. Grow into **Red Team Lead / Security Consultant**.

ROADMAP FOR ETHICAL HACKER

➔ Plan is for 12 Months (48 MONTHS) Program:
➔ It was planned in the phases form

PHASE LAYOUT (48 WEEKS)

- **Phase 0 --- Foundations : Week 1 - 8**
- **Phase 1 --- Core Pentesting Tools and Web : Week 9 - 20**
- **Phase 2 --- Hands on Full Stacks Labs (boxes) : Week 21 - 32**
- **Phase 3 --- Advanced Topics and Specialization : Week 33 - 44**
- **Phase 4 --- Certifications, Portfolio and job Prep : Week 45 - 48**

Weekly Plan:

Phase 0 — Foundations (Weeks 1–8) — build the base

Goal: Networking, OS, scripting fundamentals so nothing breaks your flow later.

Week 1 — TCP/IP basics

- Learn: OSI vs TCP/IP, IP addressing, subnets, default gateway, ARP.
- Do: Subnetting drills (CIDR), sketch network diagrams.
- Tools: Wireshark capture basics (record localhost traffic).

Week 2 — Network protocols & services

- Learn: DNS, DHCP, HTTP(S), SMTP, SSH, SMB.
- Do: Use dig/nslookup, curl requests, inspect with Wireshark.
- Lab: Small home lab — run a web server (nginx) and inspect traffic.

Week 3 — Linux fundamentals

- Learn: Filesystem, permissions, users, processes, systemd, package managers.
- Do: Daily CLI tasks; write basic Bash scripts (enumeration scripts).
- Tools: grep, awk, sed, netstat/ss, ps, top.

Week 4 — Windows fundamentals & Active Directory intro

- Learn: Windows file system, registry, services, Event Viewer, SMB.
- Do: Setup Windows VM, join a domain (basic lab).
- Read: intro to AD components (Domain Controllers, users, groups, GPO).

Week 5 — Scripting basics — Python

- Learn: Python 3 fundamentals (requests, subprocess, argparse).
- Do: Build small tools: port scanner using socket, simple HTTP request script.
- Repo: Create GitHub repo "scripts/foundations".

Week 6 — PowerShell & Bash for pentesters

- Learn: PowerShell core concepts, remoting basics, useful cmdlets.
- Do: Write PowerShell script to enumerate system info; port to Bash variant.

Week 7 — Web fundamentals & OWASP Top 10 intro

- Learn: HTML, forms, cookies, sessions, headers, REST APIs.
- Do: Manually submit forms with curl; parse responses. Read OWASP Top 10.

Week 8 — Version control & lab setup

- Do: Set up GitHub, create README, push scripts. Build VM lab environment (VirtualBox/VMware), install Kali, Windows Server + AD lab, basic router NAT rules.
- Milestone: You can explain TCP/IP, run Linux/Windows VMs, write a simple Python script, and push to GitHub.

Phase 1 — Core Pentesting Tools & Web (Weeks 9–20)

Goal: Master core tooling, web app attacks, and basic exploitation workflows.

Week 9 — Reconnaissance tools

- Tools: Nmap deep dive (scripts, timing, NSE), masscan, Amass for subdomain discovery.
- Do: Create Nmap scan templates; run recon on intentionally vulnerable VMs.

Week 10 — Web proxy & Burp Suite

- Tools: Burp Suite (Community + Burp Extender basics), Repeater, Intruder patterns.
- Do: Intercept app, modify requests, learn parameter tampering.

Week 11 — SQLi & Authentication flaws

- Learn: SQL injection types (in-band, blind), bypassing auth, logic flaws.
- Do: Exploit vulnerable DVWA/Mutillidae boxes; write proof-of-concept SQLi payloads.

Week 12 — XSS, CSRF, and other web bugs

- Learn: Reflected, stored, DOM XSS; CSRF tokens, SameSite, secure cookie flags.
- Do: PoC XSS payloads, simulate CSRF attack and mitigation.

Week 13 — Scanners & vuln validation

- Tools: Nikto, OWASP ZAP, Nessus/OpenVAS basics.
- Do: Scan web targets, triage findings (false positives vs real vulns).

Week 14 — Password attacks & cracking

- Tools: John the Ripper, Hashcat, Hydra.
- Do: Extract hashes from Linux (shadow) and Windows (NTDS slope), practice cracking small lists.

Week 15 — Exploitation basics & Metasploit

- Learn: Exploit vs payload vs shell, manual exploit steps.
- Tools: Metasploit usage, but focus on manual exploitation flow.
- Do: Exploit common services in lab with and without Metasploit.

Week 16 — Traffic analysis & intermediate networking

- Tools: Wireshark advanced filters, tcpdump, netcat.
- Do: Capture and analyze multi-step protocols, reconstruct TCP streams.

Week 17 — Post-exploitation basics

- Learn: Triage after shell, pivoting, privilege escalation basics, persistence.
- Tools: Meterpreter basics, linpeas, winpeas, pspy.
- Do: Enumerate a compromised box and escalate privileges in lab.

Week 18 — Web logic & API testing

- Learn: Broken auth, insecure direct object refs (IDOR), JWT flaws.
- Do: Test APIs, manipulate tokens, identify logic flaws.

Week 19 — Reporting basics

- Learn: Structure of pentest report — exec summary, vuln list, PoC, remediation.
- Do: Write 1 short report from a lab you broke in previous weeks.

Week 20 — Consolidation week

- Do: Finish any unfinished labs, polish scripts, publish 2 writeups.
- Milestone: You can compromise standard web apps, crack some passwords, and produce a coherent report.

Phase 2 — Hands-on Full-Stack Labs & AD (Weeks 21–32)

Goal: Large volume of real boxes: Linux privesc, Windows AD estate, network pivoting, timed practice.

Week 21 — TryHackMe / HTB routine

- Do: Finish 2-3 beginner HTB retired Linux boxes. Time yourself and write a full writeup for each.

Week 22 — Linux privilege escalation deep dive

- Learn: SUID, misconfigured cron, kernel exploits basics.

- Tools: LinPEAS, GTFOBins, strace, /proc analysis.
- Do: 3 Linux privsec boxes.

Week 23 — Windows privilege escalation deep dive

- Learn: DLL hijack, service misconfig, scheduled tasks, UAC bypasses.
- Tools: WinPEAS, PowerUp, PowerSploit.
- Do: 3 Windows boxes.

Week 24 — Active Directory fundamentals

- Learn: Kerberos basics, LDAP, SPNs, account types, trusts.
- Do: Build a small AD lab (DC + multi-hosts).

Week 25 — AD enumeration & common attacks

- Tools: BloodHound/SharpHound, CrackMapExec, Impacket.
- Do: Simulate Kerberoasting, AS-REP, NTLM relay (lab safe).

Week 26 — AD privilege escalation chains

- Learn: Lateral movement vectors, abuse of delegated rights, GPO misconfig.
- Do: Break into an AD lab from user to domain admin; document chain.

Week 27 — Pivoting & multi-hop engagements

- Tools: SSH tunnels, proxychains, SOCKS, Chisel, smbclient.
- Do: Compromise a DMZ host and pivot to internal network.

Week 28 — Realistic scenario box marathon

- Do: Complete 4 medium/large retired HTB boxes (include at least one AD box). Time-box each attempt to simulate real engagement.

Week 29 — CTF-style exploit writing

- Learn: Buffer overflow intro, ROP concept basics.
- Tools: GDB, pwntools.
- Do: One simple pwn challenge; write solution.

Week 30 — Web app advanced (business logic)

- Do: Target complex web logic boxes and APIs; produce in-depth writeups.

Week 31 — Cloud basics

- Learn: IAM basics (AWS & Azure), metadata service, common misconfigurations.
- Do: Practice on intentionally vulnerable cloud labs (try to enumerate S3 buckets, metadata exploitation in lab environments).

Week 32 — Consolidation & public writeups

- Do: Publish 4 strong writeups (Linux, Windows, AD, cloud). Create a pentest-style report for one box.
- Milestone: You can fully compromise AD lab, pivot networks, and write professional reports.

Phase 3 — Advanced Topics & Specialization (Weeks 33–44)

Goal: Specialized, high-value skills: exploit dev, cloud, automation, red-team TTPs, and OSCP prep.

Week 33 — Automation & tooling (Python advanced)

- Learn: pwntools, requests, asyncio, socket automation.
- Do: Build a scanner/enumerator for a small problem (GitHub project).

Week 34 — Active Directory advanced (Kerberos / Silver ticket / Rubeus)

- Tools: Rubeus, Kekeo, Mimikatz (in safe lab).
- Do: Perform Kerberoast and analyze output; practice silver/golden ticket concepts offline.

Week 35 — AD defense & attack crossover

- Learn: How defenders detect common AD attacks (Event IDs, logs).
- Do: Configure logging in your lab and simulate detection; write an improvement plan.

Week 36 — Cloud deep dive (AWS & Azure)

- Learn: IAM roles, STS, roles chaining, managed identities, SAS tokens.
- Do: Break misconfigured S3/Azure Blob access in labs; pivot to server.

Week 37 — Exploit development intro

- Learn: Memory layout, buffer overflows, format strings, shellcode basics.
- Tools: GDB, pwndbg, radare2/ghidra basics.
- Do: Solve 2 simple binary exploitation exercises.

Week 38 — Reverse engineering basics

- Learn: Static vs dynamic RE, reading assembly, decompiling.
- Do: Decompile a small binary, find hard-coded credentials or logic bug.

Week 39 — Offensive cloud persistence & post-exploit

- Learn: Long-term footholds, keys exfiltration, identity abuse.
- Do: Demonstrate persistent access in a lab (rotate keys safely).

Week 40 — Red Team TTPs & OPSEC

- Learn: Command & Control basics (C2 concepts), OpSec hygiene, staging.
- Do: Read/write a mini playbook of TTPs and mitigations.

Week 41 — Advanced web issues & APIs

- Learn: Server-Side Request Forgery (SSRF), deserialization attacks, prototype pollution.

- Do: Exploit SSRF in lab, chain to internal service access.

Week 42 — Wireless & hardware intro (optional)

- Learn: WPA2/3 basics, packet injection, Bluetooth basics.
- Do: Capture Wi-Fi handshakes and practice offline cracking (in permitted lab).

Week 43 — Build a red-team style engagement

- Do: Plan and execute a full-scope lab engagement: recon → exploit → pivot → domain takeover → data exfil → report.

Week 44 — OSCP focused practice

- Do: Time-boxed 24–48 hour practice box simulation, practice documenting every step. Focus on manual exploitation, privilege escalation, and report writing under time pressure.
- Milestone: You can reliably finish medium-hard boxes within a working timeframe and write clear PoCs.

Phase 4 — Certification, Portfolio & Job Prep (Weeks 45–48)

Goal: Final polish, cert attempts, interview prep, and applying for roles.

Week 45 — Certification prep (eJPT / PNPT)

- Choose a practical cert (eJPT or PNPT). Finish their labs and mock exams.
- Do: Take the eJPT/PNPT exam (or schedule OSCP lab if ready).

Week 46 — OSCP Prep Sprint

- If aiming OSCP: intensify 40–60 hrs/week practice for this week — simulate the 24-hour exam: pick 4 boxes, root & document everything.
- If not OSCP yet: finish outstanding labs and solidify writeups.

Week 47 — Portfolio & resume polish

- Do: Publish 10+ writeups on GitHub/blog; prepare 3 pentest report samples (redacted). Update LinkedIn/resume with labs, certs, GitHub link.
- Mock interviews: technical questions + walkthrough of a box.

Week 48 — Job applications & interview blitz

- Do: Apply to entry-level pentester roles, junior red team, or bug bounty/contract gigs. Continue CTFs and labs while interviewing.
- Milestone: Have at least 3 job applications sent with tailored resumes and portfolio links.

Certifications Timeline & Recommendations

- Months 3 – 4: eJPT or eJPT – equivalent / PNPT (practical, showsm baseline pentest skill).

- Months 9 – 12: OSCP attempt when can reliably do 24 – 48 hour boxes and write clean reports.
- Month 12 : Ethical Hacker Certification (you have to be the certified ethical hcker)

Languages & tech to master:

1. **Python** — automation, exploit scripts, tooling.
2. **Bash** — Linux automation.
3. **PowerShell** — Windows post-exploitation & red team scripts.
4. **JavaScript** — web app attacks & API understanding.
5. **SQL** — injection and DB logic.
6. **C / C++** — optional for exploit dev & memory work.
7. **YAML / JSON / Terraform basics** — infra-as-code, cloud configs.
8. **Git** — version control for everything.

Tool / tech checklist (Should master)

- **Recon: Nmap, masscan, Amass, Subfinder**
- **Web: Burp Suite, OWASP ZAP, sqlmap (as learning tool)**
- **Exploit: Metasploit (as tool), manual buffer overflow basics, pwntools**
- **AD: BloodHound, SharpHound, Rubeus, Impacket, CrackMapExec**
- **Passwords: Hashcat, John the Ripper**
- **Monitoring/analysis: Wireshark, Sysinternals (Windows), ELK basics**
- **Cloud: AWS/azure CLI, basic IAM console work**
- **Forensics/RE: Ghidra, radare2, strings, ltrace**

Projects to build & showcase (must-have)

- **GitHub: repo with 10+ scripts (enumeration, automated report templating).**
- **Blog: 10 public writeups (one per major skill area).**
- **Pentest report: 3 redacted professional reports (PDF).**
- **Tool: small original utility (e.g., custom recon aggregator, Burp extension, or credential brute-force harness).**
- **CTF wins: highlight Top 10 finishes or solved high-value challenges.**